API SECURITY TESTING

Exploiting an API endpoint using documentation

PortSwigger Web Security Academy Lab Report

Platform:	PortSwigger Web Security Academy
Tool:	Burp Suite Community Edition
Category:	API Testing
Status:	Completed

Practical testing performed in an authorized training environment.

Contents

1 Objective

Use publicly available API documentation to identify an API operation and demonstrate that it permits an unauthorized user-management action.

2 Methodology

1. Inspected the application and identified its API documentation endpoint.
2. Reviewed the documentation to understand the available API routes and the operations they supported.
3. Inspected the account page and its related request to understand the API structure used by the application.
4. Used the documented user-management route in Burp Suite and sent a DELETE request for the user named carlos.
5. Reviewed the server response. The API returned HTTP 200 OK with the message "User deleted".
6. Confirmed that the lab displayed its successful completion message.

3 Finding and Result

The API documentation exposed the available user-management operation. The DELETE request was accepted in the authenticated lab session and removed the carlos account.

4 Potential Impact

If similar access were available to an ordinary user in a real application, a user could potentially delete another account. The impact depends on the application's authorization rules and the privileges of the account making the request.

5 Recommendations

- Require server-side authorization checks for every user-management operation.
- Verify that the authenticated user is permitted to delete the specific account identified in the request.
- Limit access to API documentation where appropriate, while not treating hidden documentation as a replacement for authorization.
- Log and monitor sensitive account-management actions.

6 Evidence

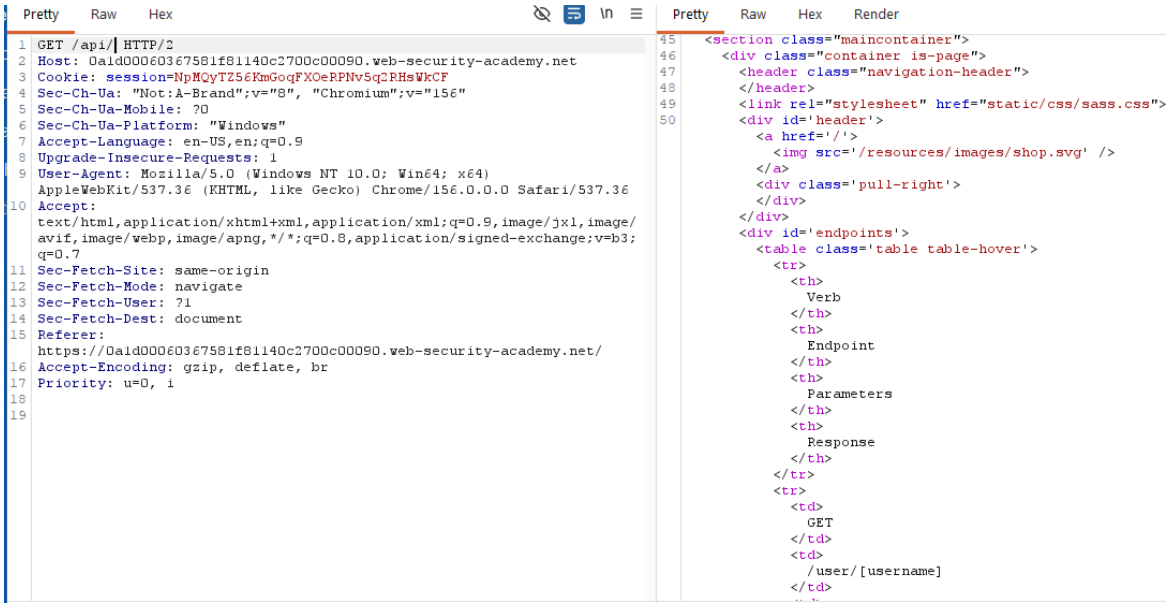


Figure 1: API documentation response showing the documented API structure.



Figure 2: Account page response showing the application's API usage.



Figure 3: DELETE request to the user endpoint and the successful server response.

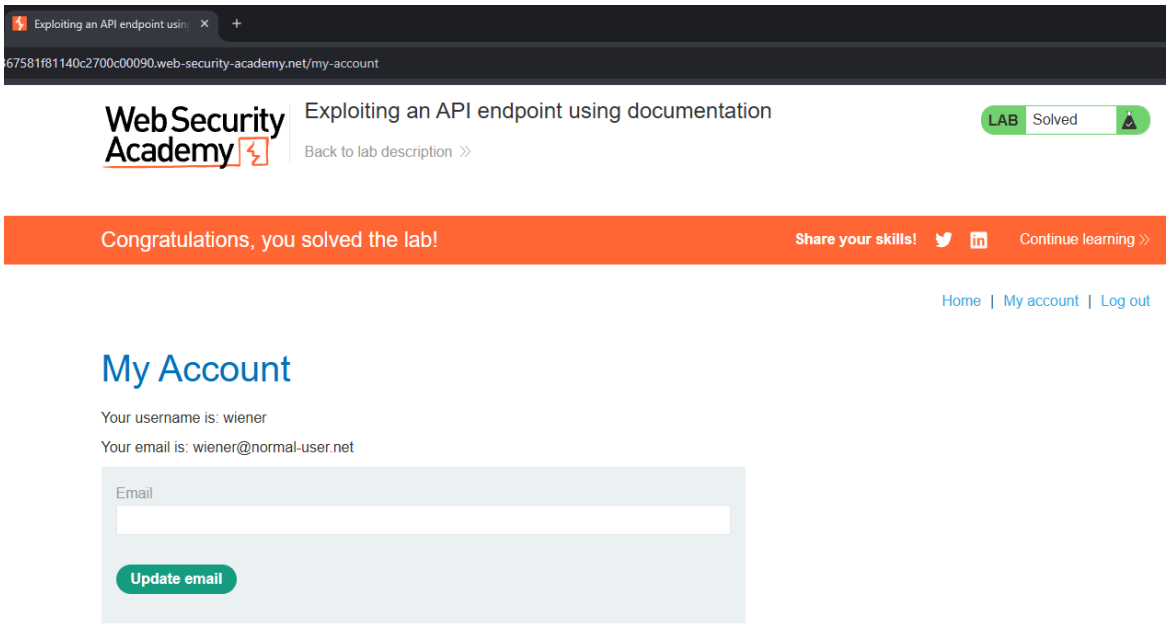


Figure 4: PortSwigger confirmation that the lab was solved.

7 Conclusion

The exercise showed how API documentation can help a tester discover operations that are not obvious from the user interface. It also demonstrated why sensitive API operations must enforce authorization on the server.

Disclaimer: All testing was conducted in the authorized PortSwigger Web Security Academy lab environment.